

Seguridad de la Información

PRÁCTICA 9: ANÁLISIS COMPARATIVO DE VULNERABILIDADES CVE

SI – CURSO 2025-2026 – PRÁCTICA 9 – SERGIO ACOSTA QUINTANA

ANÁLISIS COMPARATIVO DE VULNERABILIDADES:

CVE-2026-33824 - CVE-2026-23112 - CVE-2025-43359

Fecha: 3 de mayo de 2026

Índice general

Índice de figuras	2
Índice de tablas	3
1. Introducción a CVE, CVSS y las bases de datos principales	4
2. Proceso de selección	5
2.1. Criterios obligatorios	5
2.2. Capturas del proceso	6
2.3. Candidatos descartados	7
3. Ficha técnica comparativa	9
4. Análisis individual de cada CVE	11
4.1. CVE-2026-33824 (Windows IKEv2)	11
4.2. CVE-2026-23112 (Linux Kernel nvmet-tcp)	12
4.3. CVE-2025-43359 (Apple Kernel)	13
5. Análisis comparativo	14
6. Noticias o avisos públicos relacionados	16
7. Conclusiones	18
8. Bibliografía	19

Índice de figuras

2.1. Aplicación de los filtros de CVSS, vector y fecha en la NVD.	6
2.2. Lista de resultados obtenidos tras aplicar los criterios de búsqueda.	7
2.3. Historial de navegación al finalizar la búsqueda y la validación de las CVE seleccionadas.	7

Índice de cuadros

2.1. Comprobación del cumplimiento de los criterios obligatorios.	6
2.2. Vulnerabilidades descartadas.	8
2.3. Justificación de que las CVE elegidas afectan a componentes del sistema base.	8
3.1. Ficha de las tres vulnerabilidades elegidas.	9
3.2. Fuentes primarias y secundarias utilizadas para cada CVE.	10
5.1. Ventana aproximada de exposición inicial de las CVE analizadas.	14

Capítulo 1

Introducción a CVE, CVSS y las bases de datos principales

Para que los profesionales de la seguridad informática puedan identificar unívocamente los fallos de software, se utilizan estándares globales. El programa **CVE (Common Vulnerabilities and Exposures)** actúa como un diccionario público donde se registran las vulnerabilidades descubiertas. La organización encargada de coordinarlo es MITRE, aunque la asignación de los identificadores (por ejemplo, CVE-2026-XXXX) recae directamente en las **CNA (CVE Numbering Authorities)**. Estas entidades suelen ser grandes empresas tecnológicas, como Microsoft o Google, o grupos de investigadores debidamente autorizados.

Para medir la gravedad de cada fallo se usa el sistema **CVSS (Common Vulnerability Scoring System)**. Conviene aclarar que la puntuación CVSS, que va de 0 a 10, no mide el riesgo real de una organización concreta, sino la severidad técnica del fallo. Para calcularla se tienen en cuenta aspectos como si el ataque puede hacerse por red, si requiere autenticación previa y qué impacto tendría sobre la confidencialidad, integridad y disponibilidad del sistema [8, 7]. El estándar CVSS tiene varias versiones; hoy en día conviven la v3.1, que sigue siendo la más usada, y la v4.0, publicada en 2023 y todavía en adopción. La puntuación se divide en métricas Base, Temporales y Ambientales. Las Base describen el fallo en sí, las Temporales reflejan la situación actual del exploit y las contramedidas, y las Ambientales ajustan la severidad al entorno concreto. La puntuación Base se clasifica en cuatro niveles: Low (0.1–3.9), Medium (4.0–6.9), High (7.0–8.9) y Critical (9.0–10.0).

Para consultar esta información existen varias plataformas. **CVE.org** es el registro oficial de MITRE y suele centrarse en la descripción básica del fallo y en las referencias que aporta la CNA. La **NVD (National Vulnerability Database)** del NIST parte de esos registros y añade más información, como métricas CVSS, CPE afectados y estados de análisis. Además, NVD puede mostrar métricas calculadas tanto por la CNA emisora como por publicadores de datos adicionales (ADP, *Additional Data Publishers*) como CISA, de modo que una misma CVE puede aparecer con puntuaciones distintas según la fuente. En resumen, CVE.org es el registro principal y la NVD funciona como una capa de análisis sobre ese registro. Por último, **FIRST.org** no es una base de datos de vulnerabilidades, sino la organización que mantiene la especificación del sistema CVSS.

Capítulo 2

Proceso de selección

En esta sección se resume el procedimiento seguido para localizar y seleccionar las vulnerabilidades analizadas, ajustándolo a los requisitos exigidos en la práctica.

2.1. Criterios obligatorios

Para localizar fallos adecuados, se utilizó la Búsqueda Avanzada de la NVD con los siguientes filtros aplicados de forma simultánea:

- **Fechas:** Vulnerabilidades publicadas o modificadas a partir del 1 de abril de 2025.
- **Severidad:** Una puntuación CVSS comprendida entre **9.0** y **10.0**, correspondiente al nivel Crítico.
- **Vector de Ataque (AV):** Se seleccionó **Network (N)** para restringir la búsqueda a fallos explotables por red.
- **Privilegios (PR):** Se fijó **None (N)** para cumplir el requisito de ausencia de autenticación previa.
- **Plataformas:** Este fue el punto más restrictivo, ya que se debían buscar fallos que afectaran directamente al sistema operativo o al kernel de Windows, Linux y Apple, descartando aplicaciones o programas de terceros.

Criterio	CVE-2026-33824	CVE-2026-23112	CVE-2025-43359
Publicada o modificada desde abril de 2025	Sí	Sí	Sí
CVSS Base Score $\geq$ 9.0	Sí, 9.8	Sí, 9.8 según CNA kernel.org	Sí, 9.8
Attack Vector = Network	Sí, AV:N	Sí, AV:N según CNA kernel.org	Sí, AV:N
Privileges Required = None	Sí, PR:N	Sí, PR:N según CNA kernel.org	Sí, PR:N
User Interaction = None	Sí, UI:N	Sí, UI:N según CNA kernel.org	Sí, UI:N
Componente del sistema base	Windows IKE Extension	nvmet-tcp en el kernel Linux	Kernel de Apple
Plataforma distinta	Windows	Linux	Apple

Cuadro 2.1: Comprobación del cumplimiento de los criterios obligatorios.

En el caso de CVE-2026-23112 se utiliza la métrica CVSS 3.1 publicada en NVD/CNA `kernel.org`, que aparece como 9.8 crítica y cumple los criterios de la práctica.

2.2. Capturas del proceso

A continuación, se incluyen las capturas del proceso de configuración de filtros, la obtención de resultados y el historial final de navegación, tal como se solicita en el enunciado.

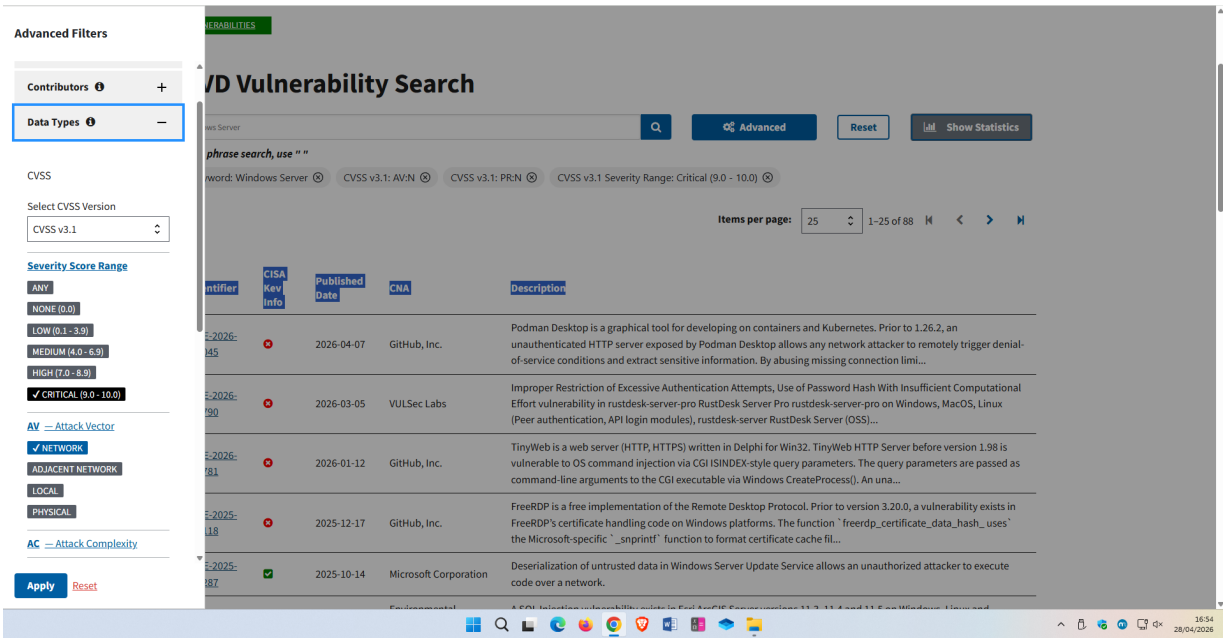


Figura 2.1: Aplicación de los filtros de CVSS, vector y fecha en la NVD.

En la Figura 2.1 se observa la búsqueda avanzada de NVD con los filtros de severidad crítica, vector remoto y ventana temporal reciente. La captura muestra la URL del navegador y la fecha u hora visible del sistema.

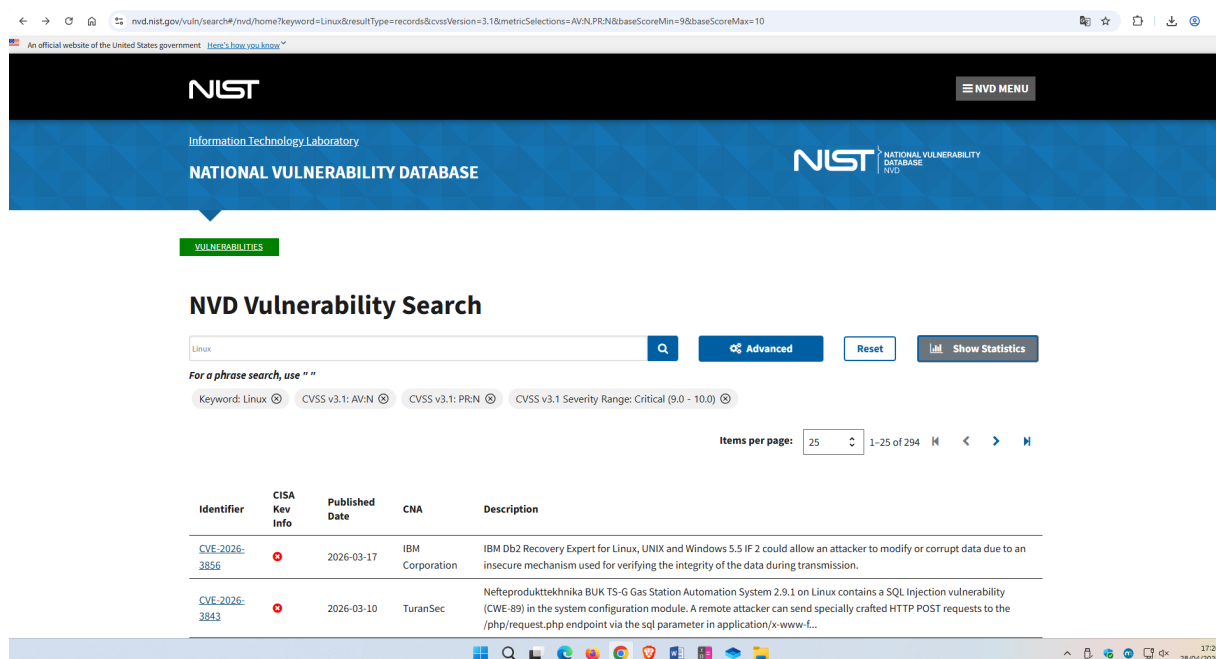


Figura 2.2: Lista de resultados obtenidos tras aplicar los criterios de búsqueda.

En la Figura 2.2 se aprecia el listado de candidatos devuelto por NVD tras aplicar los filtros anteriores, lo que permite comprobar que la selección no se realizó manualmente desde una lista previa.

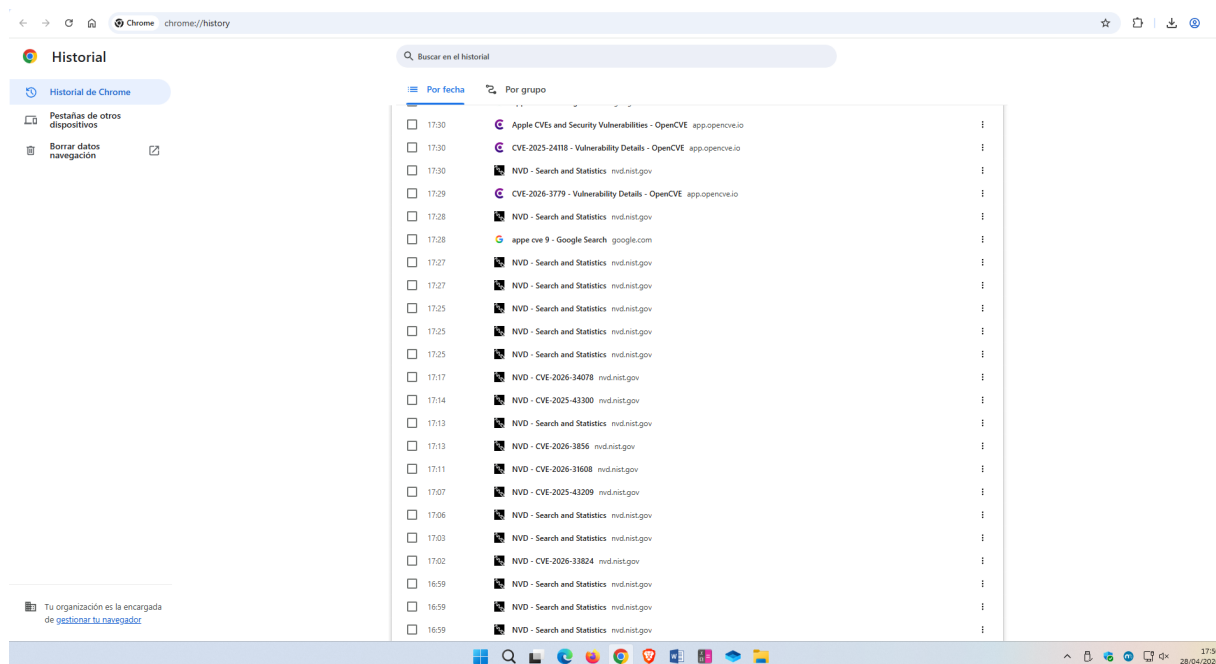


Figura 2.3: Historial de navegación al finalizar la búsqueda y la validación de las CVE seleccionadas.

En la Figura 2.3 se recoge el historial de navegación utilizado para justificar el proceso de búsqueda y contraste de fuentes. La información visible permite identificar la fecha, la hora y las páginas consultadas.

2.3. Candidatos descartados

Durante la búsqueda se revisaron varias vulnerabilidades recientes con puntuación crítica que finalmente quedaron descartadas por no cumplir alguno de los criterios obligatorios de la práctica.

CVE	Plataforma	Razón del descarte
CVE-2026-34045	Windows	El fallo reside en <i>Podman Desktop</i> . Al ser una aplicación de terceros instalada en Windows y no formar parte del sistema operativo base, fue descartada.
CVE-2025-43300	Apple	Se trataba de un problema grave de corrupción de memoria que, según Apple, se estaba explotando en ataques sofisticados. Sin embargo, para explotarlo era necesario procesar un archivo de imagen, lo que implica interacción del usuario (UI:R). Por lo tanto, no cumplía el requisito de ataque desatendido.
CVE-2026-34078	Linux	Un fallo reportado por Codean Labs que permitía evadir el sandbox en <i>Flatpak</i> . Aunque es una herramienta común, Flatpak es un framework de gestión de aplicaciones, no el kernel ni el sistema base de Linux, por lo que también fue descartado.

Cuadro 2.2: Vulnerabilidades descartadas.

Justificación de los elegidos:

La selección final se mantuvo porque los tres registros cumplen el umbral de criticidad y afectan a componentes especialmente sensibles de cada plataforma. En Windows el fallo recae sobre IKE, que suele estar expuesto en escenarios de VPN; en Linux afecta a `nvmet-tcp`, integrado en el kernel; y en Apple se trata de un problema del kernel relacionado con la gestión de sockets UDP en varios sistemas operativos del fabricante. Además, los tres registros habían sido publicados o modificados dentro del periodo exigido.

Como apoyo documental del proceso de selección, se conservaron también los enlaces directos a los registros revisados en NVD. En Windows se contrastaron <https://nvd.nist.gov/vuln/detail/CVE-2026-33824> y <https://nvd.nist.gov/vuln/detail/CVE-2026-34045>; en Apple, <https://nvd.nist.gov/vuln/detail/CVE-2025-43359> y <https://nvd.nist.gov/vuln/detail/CVE-2025-43300>; y en Linux, <https://nvd.nist.gov/vuln/detail/CVE-2026-23112> y <https://nvd.nist.gov/vuln/detail/CVE-2026-34078>. De ese conjunto, tres acabaron formando parte del análisis final y tres quedaron descartadas por no ajustarse por completo a los criterios exigidos.

CVE	Componente afectado	Por qué cuenta como sistema base
CVE-2026-33824	Windows IKE Extension	Es un componente propio de Windows relacionado con IPsec/IKEv2, no una aplicación de terceros instalada aparte.
CVE-2026-23112	<code>nvmet-tcp</code>	Es un componente del subsistema NVMe over TCP del kernel de Linux, por lo que forma parte del sistema base.
CVE-2025-43359	Kernel de Apple / gestión de sockets UDP	El fallo afecta a un componente del sistema operativo de Apple y no a una app de terceros distribuida por separado.

Cuadro 2.3: Justificación de que las CVE elegidas afectan a componentes del sistema base.

Capítulo 3

Ficha técnica comparativa

Atributo	Vulnerabilidad 1	Vulnerabilidad 2	Vulnerabilidad 3
Identificador CVE	CVE-2026-33824	CVE-2026-23112	CVE-2025-43359
Plataforma / Sistema Operativo afectado	Windows 10, Windows 11 y Windows Server	Linux kernel	iOS, iPadOS, macOS, tvOS, visionOS y watchOS
Versiones afectadas	Varias ramas de Windows 10/11/Server previas a los parches de abril de 2026 publicados por Microsoft	Según el registro CVE/kernel.org enlazado por NVD: ramas 5.0–5.10.249, 5.11–5.15.199, 5.16–6.1.162, 6.2–6.6.123, 6.7–6.12.69, 6.13–6.18.9 y 6.19-rc1–6.19-rc8	iPadOS e iOS anteriores a 18.7; macOS 14.x anterior a 14.8; macOS 15.x anterior a 15.7; tvOS, visionOS y watchOS anteriores a 26
CVSS Base Score	9.8 (CNA: Microsoft)	9.8 (CNA: kernel.org; coincide con la valoración mostrada en NVD)	9.8 (ADP: CISA)
Vector CVSS completo	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Estado / observaciones del registro en NVD	Sin etiqueta especial adicional visible; ficha NVD enriquecida con métricas CVSS y referencias	Modified After Enrichment	Modified After Enrichment
¿Figura en CISA KEV?	No, tras búsqueda exacta del identificador en el catálogo oficial (01/05/2026)	No, tras búsqueda exacta del identificador en el catálogo oficial (01/05/2026)	No, tras búsqueda exacta del identificador en el catálogo oficial (01/05/2026)
¿Existe PoC público documentado?	No. Solo consta un análisis técnico detallado de ZDI/Trend Micro, sin exploit funcional público verificable	No se ha localizado PoC público verificable en las fuentes consultadas	No se ha localizado PoC público verificable en las fuentes consultadas
Fecha del primer parche oficial	14/04/2026 (Patch Tuesday de Microsoft)	13/02/2026 en los commits enlazados por NVD; despliegue final dependiente de cada distribución	15/09/2025 (actualizaciones de Apple)
¿Era un 0-day en la publicación?	No. No consta explotación previa y parche y publicación coincidieron el mismo día	No. Los parches de kernel.org ya aparecían enlazados y no consta explotación activa previa documentada	No. No consta explotación previa y Apple lo publicó junto con la actualización

Cuadro 3.1: Ficha de las tres vulnerabilidades elegidas.

Para esta práctica se considera PoC público documentado únicamente una prueba de concepto verificable, como un repositorio con código de explotación, un módulo de Metasploit, una entrada de Exploit-DB o un análisis técnico reproducible que permita disparar la vulnerabilidad. No se han considerado suficientes las páginas que solo replican la descripción de NVD, ni las que mencionan de forma genérica la madurez del exploit sin enlazar una prueba pública reproducible. En el caso de CVE-2026-33824, se ha localizado un análisis técnico público de Zero Day Initiative / Trend Micro que describe con detalle la causa del fallo, la ruta vulnerable y pautas de detección, pero no se ha tratado como

PoC público porque no proporciona un exploit funcional listo para su uso.

La comprobación del catálogo CISA KEV se realizó buscando individualmente los identificadores CVE-2026-33824, CVE-2026-23112 y CVE-2025-43359 en el catálogo oficial de vulnerabilidades explotadas conocidas. A fecha de consulta, ninguna de las tres aparece incluida. Por tanto, no existe evidencia oficial de CISA de explotación activa conocida para estas vulnerabilidades. En cuanto al estado mostrado por NVD, la etiqueta *Modified After Enrichment* indica que el registro cambió después del enriquecimiento inicial realizado por NVD y que, por tanto, los metadatos enriquecidos pueden requerir revisión posterior.

CVE	Fuente primaria principal	Fuente secundaria
CVE-2026-33824	NVD / MSRC	ZDI / The Hacker News
CVE-2026-23112	NVD / kernel.org	Beeks Group
CVE-2025-43359	NVD / Apple	Cyber Press

Cuadro 3.2: Fuentes primarias y secundarias utilizadas para cada CVE.

Capítulo 4

Análisis individual de cada CVE

4.1. CVE-2026-33824 (Windows IKEv2)

Origen y descubrimiento:

La NVD describe esta CVE como un *double free* en Windows IKE Extension que permite ejecución remota de código a un atacante no autenticado a través de la red [1, 11]. En el registro CVE 5.2 figura como *Published*, con reserva del identificador el 24 de marzo de 2026, publicación el 14 de abril de 2026 y última actualización el 30 de abril de 2026. Microsoft atribuye el descubrimiento al equipo WARP & MORSE [11].

¿Era un 0-day?

No. Un 0-day implica que la vulnerabilidad ya se estaba explotando o era conocida antes de que el fabricante tuviera parche disponible. En este caso, Microsoft publicó la corrección el mismo 14 de abril de 2026, junto con la publicación del registro y del ciclo Patch Tuesday. Además, no hay evidencia pública de explotación previa ni entrada en CISA KEV. Por eso, encaja mejor como divulgación coordinada que como 0-day.

Descripción técnica:

El fallo reside en el componente IKEv2 de Windows, usado para la negociación de túneles IPsec y VPN. La debilidad catalogada es **CWE-415 (Double Free)**. En términos prácticos, el servicio libera dos veces una misma zona de memoria, lo que abre la puerta a corrupción de memoria y, según el propio registro, a ejecución remota de código enviando tráfico especialmente preparado por red.

Traducción del vector CVSS:

En este caso, **AV:N** encaja con la propia descripción oficial, que habla de explotación por red. **AC:L** indica que no se mencionan condiciones previas especialmente difíciles. **PR:N** significa que no se exigen credenciales en el sistema objetivo, algo coherente con un servicio de red expuesto antes de la autenticación. **UI:N** también resulta razonable porque el ataque no depende de que una persona abra un archivo o pulse sobre un enlace. **S:U** (Scope Unchanged) indica que el impacto de la explotación se limita al sistema que ejecuta el servicio IKEv2 vulnerable, sin que el atacante pueda pasar automáticamente a otros sistemas mediante la propia vulnerabilidad. Aunque IKEv2 gestiona túneles VPN que conectan múltiples equipos, el fallo de *double free* ocurre en el propio proceso del servicio Windows y no otorga control directo sobre los extremos remotos del túnel. Por último, el trío **C:H/I:H/A:H** refleja que, si la explotación llega a materializarse, el impacto potencial sobre confidencialidad, integridad y disponibilidad es muy alto.

Impacto real observado:

En las fuentes oficiales consultadas no consta explotación activa ni presencia en el catálogo CISA KEV. Tampoco se ha localizado un PoC público verificable en forma de exploit funcional o módulo de explotación. No obstante, sí existe un análisis técnico público de Zero Day Initiative / Trend Micro que describe la causa del fallo, el flujo vulnerable en IKEv2 y posibles pautas de detección [12]. Por

ello, a fecha de revisión, se considera una vulnerabilidad crítica con alto potencial técnico, pero sin evidencia pública suficiente para clasificarla como explotada activamente ni como acompañada de PoC explotable.

Estado de la mitigación:

La medida principal es aplicar los parches publicados por Microsoft el 14 de abril de 2026 [11]. Mientras se despliega la actualización, una mitigación razonable consiste en restringir la exposición del servicio IKEv2, por ejemplo limitando qué direcciones pueden alcanzar los puertos usados por IPsec o deshabilitando temporalmente el servicio si no es necesario.

4.2. CVE-2026-23112 (Linux Kernel nvmet-tcp)

Origen y descubrimiento:

Este registro aparece en CVE.org con estado *Published*, reserva del identificador el 13 de enero de 2026, publicación el 13 de febrero de 2026 y última actualización el 3 de abril de 2026 [3, 14]. El registro enlaza directamente commits de corrección en `kernel.org`, así que desde el principio se puede relacionar la CVE con su parche técnico [14].

¿Era un 0-day?

No. El registro ya enlaza parches públicos de `kernel.org` y no consta explotación activa previa ni inclusión en CISA KEV. Por eso encaja mejor como una divulgación técnica coordinada que como un 0-day documentado.

Descripción técnica:

La vulnerabilidad afecta a `nvmet-tcp`, el componente del kernel Linux que implementa el objetivo NVMe sobre TCP. El problema aparece en `nvmet_tcp_build_pdu_iovec()`, que puede avanzar más allá de `cmd->req.sg` si la longitud o el desplazamiento de una PDU supera `sg_cnt`. A partir de ahí, el código puede usar valores no válidos de `sg->length` y `sg->offset`, provocando fallos como GPF o trazas KASAN. NVD lo clasifica como **CWE-787 (Out-of-bounds Write)** [3]. El detalle importante es que el error está en una comprobación de límites ausente dentro de una ruta del kernel expuesta a tráfico NVMe/TCP.

Traducción del vector CVSS:

Aquí la situación es más simple que en la CVE de Linux anterior. NVD muestra una puntuación **9.8** que coincide con la de la CNA `kernel.org`, con el vector **CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H** [3]. **AV:N** se entiende porque `nvmet-tcp` es un servicio de red. **AC:L** indica que no se describen condiciones previas especialmente complejas. **PR:N** y **UI:N** encajan con un ataque que se lanza enviando tráfico especialmente preparado al servicio, sin depender de credenciales previas ni de la intervención del usuario. **S:U** mantiene el impacto dentro del mismo sistema afectado y **C:H/I:H/A:H** refleja que un fallo en una ruta del kernel puede tener consecuencias graves si se llega a explotar.

Impacto real observado:

No se ha localizado evidencia oficial de explotación activa ni inclusión en CISA KEV. Tampoco aparece un PoC público verificado en las fuentes oficiales consultadas. Por eso, lo razonable es tratarlo como un riesgo serio para sistemas que expongan `nvmet-tcp`, pero sin exagerar su explotación real si no hay datos públicos que lo respalden.

Estado de la mitigación:

La mitigación principal es actualizar a una versión del kernel que incorpore los commits de corrección enlazados por NVD [3, 14]. Avisos posteriores de fabricantes y distribuciones, como SUSE, Ubuntu o Debian, también reflejan su tratamiento dentro de actualizaciones de seguridad. Si el servicio `nvmet-tcp` no es imprescindible, una medida temporal prudente es deshabilitarlo o limitar su exposición a redes de confianza hasta completar la actualización.

4.3. CVE-2025-43359 (Apple Kernel)

Origen y descubrimiento:

El registro aparece en CVE.org con estado *Published*, reserva del identificador el 16 de abril de 2025, publicación el 15 de septiembre de 2025 y última actualización el 2 de abril de 2026 [5, 13]. En el aviso de seguridad consultado, Apple atribuye esta CVE a Viktor Oreshkin, pero no añade más información sobre su afiliación, así que solo puede decirse con seguridad que es un investigador citado por el fabricante [13].

¿Era un 0-day?

No. Apple publicó las actualizaciones correctoras el mismo 15 de septiembre de 2025, la misma fecha que el aviso de seguridad. No consta explotación activa previa documentada ni entrada en CISA KEV, por lo que no puede calificarse como 0-day con la información pública disponible.

Descripción técnica:

La descripción pública disponible es más clara que en otros casos de Apple. El fallo está en la lógica de vinculación (*bind*) de sockets UDP en el kernel. Cuando una aplicación crea un socket de servidor UDP y lo vincula a una interfaz concreta, el código afectado no valida bien el estado final de esa vinculación. Como consecuencia, el socket puede acabar escuchando en todas las interfaces de red en lugar de quedarse solo en la prevista. Apple lo describe como un problema de lógica corregido mediante una mejora en la gestión de estado y NVD lo asocia a **CWE-670 (Always-Incorrect Control Flow Implementation)** [5, 13]. En la práctica, eso amplía de forma no prevista la superficie de exposición del servicio.

Traducción del vector CVSS:

En esta CVE el vector de NVD resulta más coherente con la descripción pública que en otros casos de Apple. **AV:N** se entiende porque el problema afecta a un socket UDP y puede dejar expuesto un servicio por red más allá de la interfaz prevista. **AC:L** indica que no se describen condiciones de explotación especialmente complejas. **PR:N** y **UI:N** reflejan que el escenario valorado por CISA-ADP no depende de credenciales previas ni de interacción del usuario. **S:U** mantiene el impacto dentro del mismo sistema afectado. Conviene matizar que el trío **C:H/I:H/A:H** procede de la valoración ADP/CISA mostrada por NVD y debe interpretarse como un escenario de impacto potencial alto si esa exposición inesperada del servicio llegara a aprovecharse con éxito, no como prueba de explotación remota generalizada o automática sobre cualquier dispositivo Apple [5].

Impacto real observado:

En las fuentes oficiales consultadas no aparece constancia de explotación activa ni inclusión en CISA KEV. Por ello, lo correcto es señalar que se trata de un fallo grave según la puntuación registrada, aunque sin evidencia pública confirmada de explotación real.

Estado de la mitigación:

Apple lo corrigió el mismo 15 de septiembre de 2025 mediante actualizaciones para iOS 18.7, iPadOS 18.7, iOS 26, iPadOS 26, macOS Sonoma 14.8, macOS Sequoia 15.7, macOS Tahoe 26, tvOS 26, visionOS 26 y watchOS 26 [5, 13]. La recomendación práctica es sencilla: instalar las versiones corregidas publicadas por el fabricante.

Capítulo 5

Análisis comparativo

1. Riesgo en entorno corporativo vs. doméstico:

Para un usuario doméstico, **CVE-2025-43359** puede ser la más relevante porque afecta a dispositivos Apple de uso cotidiano y su descripción apunta a una exposición de red no prevista en sockets UDP. No obstante, su riesgo real depende de que exista un servicio UDP afectado cuya exposición se vea ampliada por el fallo, por lo que no debe interpretarse como una explotación automática contra cualquier usuario doméstico. En cambio, en una empresa el mayor riesgo práctico suele desplazarse hacia **CVE-2026-33824**, ya que IKEv2 se utiliza con frecuencia en servicios VPN o en infraestructuras perimetrales. **CVE-2026-23112** sería especialmente preocupante en empresas que usen NVMe over TCP para almacenamiento o infraestructura interna, aunque para un usuario doméstico típico su exposición real sería menor porque no suele tener `nvmet-tcp` habilitado ni expuesto. La diferencia entre ambos contextos está en la superficie de exposición: en casa suele haber menos servicios de red accesibles desde fuera, mientras que en una organización sí puede haber componentes deliberadamente publicados.

2. Impacto de la ventana de exposición:

En estas tres CVE la ventana entre publicación y disponibilidad inicial del parche no es larga, porque los tres casos llegan al público ya con correcciones disponibles o con referencias directas al parche. La situación se resume en la tabla siguiente:

CVE	Publicación CVE	Primer parche oficial	Ventana aprox.
CVE-2026-33824	14/04/2026	14/04/2026	0 días
CVE-2026-23112	13/02/2026	13/02/2026 / commits ya publicados	0 días o muy baja
CVE-2025-43359	15/09/2025	15/09/2025	0 días

Cuadro 5.1: Ventana aproximada de exposición inicial de las CVE analizadas.

Aun así, eso no elimina el problema operativo: una ventana corta en origen puede convertirse en una ventana real más amplia si la organización tarda en desplegar el parche. Aunque los tres parches estaban disponibles el mismo día de publicación, el plazo real para un administrador empieza cuando la corrección llega al canal de actualización de su sistema o de su distribución, y eso puede llevar más tiempo. Mientras tanto, las mitigaciones temporales son la barrera principal: en CVE-2026-33824 conviene restringir IKEv2 en los puertos UDP 500 y 4500 mediante firewall perimetral; en CVE-2026-23112, deshabilitar `nvmet-tcp` si no es imprescindible o limitar su exposición a redes de confianza; y en CVE-2025-43359, priorizar la actualización de dispositivos Apple que ofrezcan servicios o procesen tráfico UDP sensible. Además, cuando ya existe análisis técnico público, como el de ZDI para CVE-2026-33824, el tiempo necesario para preparar intentos de explotación puede reducirse, así que esa

ventana puede ser más delicada de lo que sugiere el simple “0 días” de la tabla [1, 3, 5, 11, 13, 14, 12].

3. Priorización del parcheo:

Si hubiera que priorizar con recursos limitados, el primer criterio no debería ser solo el CVSS, aunque en este caso las tres comparten un 9.8. El orden más razonable sería: primero **CVE-2026-33824**, si IKEv2 está expuesto; después **CVE-2026-23112**, si `nvmet-tcp` está habilitado y accesible por red; y por último **CVE-2025-43359**, salvo que existan dispositivos Apple especialmente sensibles o muy extendidos dentro de la organización. Este orden se basa en la exposición real, el tipo de servicio afectado y la posibilidad de que un fallo remoto en un componente de infraestructura tenga un efecto más amplio.

4. Relevancia del catálogo CISA KEV:

Que una CVE figure en el catálogo **CISA KEV** significa que existe evidencia de explotación activa en casos reales, no solo una posibilidad teórica [9]. Eso cambia bastante la priorización, porque añade urgencia inmediata. Tras consultar directamente el catálogo CISA KEV el 1 de mayo de 2026, ninguna de las tres CVE analizadas aparece incluida en él [9]. Por tanto, la prioridad todavía puede valorarse según la exposición real del servicio y la importancia del sistema afectado. Si CVE-2026-33824 entrase en KEV, el cambio sería el más importante para entornos corporativos, porque IKEv2 suele estar expuesto en el perímetro y una explotación activa confirmada obligaría a aplicar el parche cuanto antes. En ese caso, el orden de prioridad pasaría a ser: primero CVE-2026-33824, después CVE-2026-23112 y, por último, CVE-2025-43359.

Capítulo 6

Noticias o avisos públicos relacionados

En el caso de **CVE-2026-23112**, la fuente relacionada utilizada es un aviso público centrado en esta vulnerabilidad. Se incluye porque resume el fallo, menciona sistemas afectados y propone mitigaciones inmediatas, aunque la base técnica del análisis sigue siendo NVD y `kernel.org`.

CVE a la que se refiere: CVE-2026-33824

Fecha de la noticia: 15/04/2026

Título de la noticia: Microsoft Issues Patches for SharePoint Zero-Day and 168 Other New Vulnerabilities

Enlace a la noticia: <https://thehackernews.com/2026/04/microsoft-issues-patches-for-sharepoint.html>

Breve resumen:

La noticia sitúa a CVE-2026-33824 dentro del conjunto de vulnerabilidades corregidas por Microsoft en el Patch Tuesday de abril de 2026. Aunque el foco principal del artículo está en una vulnerabilidad de SharePoint explotada activamente, también destaca el fallo crítico del servicio IKE de Windows por su potencial de ejecución remota de código sin autenticación y sin interacción del usuario. Lo más útil del artículo es que traduce el impacto técnico a un plano más práctico: recuerda que IKEv2 suele estar expuesto en despliegues de VPN y que, por tanto, aquí no importa solo la puntuación 9.8, sino también la superficie de ataque real. Eso ayuda a entender por qué este fallo merece atención prioritaria en entornos corporativos.

CVE a la que se refiere: CVE-2026-23112

Fecha de la noticia: 10/04/2026

Título de la noticia: Beeks Security Advisory: CVE-2026-23112 – Critical Linux Kernel NVMe/TCP Vulnerability

Enlace a la noticia: <https://beeksgroup.com/security/beeks-security-advisory-cve-2026-23112-critical-linux-kernel-nvme-tcp-vulnerability/>

Breve resumen:

El aviso de Beeks está centrado directamente en la **CVE-2026-23112**, así que encaja mejor como fuente relacionada que una noticia genérica sobre varias vulnerabilidades del kernel. El texto resume el problema en `nvmet-tcp`, explica que una PDU manipulada puede hacer que el código se salga de los límites esperados y termine provocando fallos del kernel, y lo presenta como un riesgo especialmente

relevante para sistemas que expongan el servicio NVMe/TCP. También aporta una lista de sistemas afectados y medidas inmediatas de mitigación, como actualizar el sistema operativo o deshabilitar el servicio si no es necesario. Aunque no sustituye a NVD ni a `kernel.org` como fuentes técnicas principales, sí ayuda a contextualizar la vulnerabilidad en un escenario más práctico de respuesta y administración.

CVE a la que se refiere: CVE-2025-43359

Fecha de la noticia: 16/09/2025

Título de la noticia: Critical Security Flaws in visionOS 26 Fixed as Apple Patches 18 Vulnerabilities

Enlace a la noticia: <https://cyberpress.org/flaws-in-visionos/>

Breve resumen:

La noticia de Cyber Press resume la publicación de visionOS 26 y la presenta como una actualización de seguridad amplia que corrige dieciocho vulnerabilidades en Apple Vision Pro. Dentro de ese conjunto menciona expresamente la **CVE-2025-43359**, explicando que el fallo corregido en el kernel podía dejar expuesto un socket de servidor UDP a todas las interfaces de red en lugar de mantenerlo limitado a la interfaz prevista. El valor de la noticia está en que traduce el boletín técnico de Apple a un lenguaje más directo y contextualiza el riesgo junto a otras correcciones del mismo paquete, como problemas de privilegios, errores de memoria y fallos en componentes multimedia. Aunque no sustituye a la referencia oficial del fabricante ni al registro de NVD, sí sirve como noticia relacionada clara y pertinente para justificar la relevancia pública de esta vulnerabilidad.

Capítulo 7

Conclusiones

La práctica permite comprobar que localizar tres CVE que cumplan a la vez todos los filtros no es tan directo como puede parecer al leer el enunciado. Encontrar registros recientes, críticos, remotos, sin privilegios previos y además vinculados al sistema operativo base obliga a descartar bastantes casos que en un primer vistazo parecían válidos. Ese proceso ya deja una conclusión útil: no basta con mirar la severidad, también hay que comprobar con detalle el componente afectado y el contexto real del fallo.

Antes de realizar la práctica podía parecer que una puntuación CVSS alta bastaba para decidir la prioridad de respuesta. Sin embargo, al comparar los tres casos se aprecia que la exposición real del servicio, la calidad de la información pública disponible y la existencia o no de explotación activa pesan tanto o más que el propio número.

También se aprecia una diferencia clara en la calidad y profundidad de la información pública según la plataforma. En Linux, el registro de `nvmet-tcp` enlaza directamente los commits del kernel y permite ver con bastante claridad dónde estaba el problema y cómo se corrigió. En Windows, aunque la descripción pública es más breve, al menos el servicio afectado y el tipo de fallo quedan bastante bien delimitados. El caso más opaco es el de Apple: la puntuación de NVD es alta y el impacto potencial parece serio, pero la explicación pública del fabricante resulta mucho menos detallada. Eso obliga a trabajar con más cautela y a distinguir entre lo que el registro afirma y lo que realmente puede justificarse con la información disponible.

Otro aspecto relevante es que la métrica CVSS, por sí sola, no resuelve la priorización. En esta práctica las tres vulnerabilidades comparten un 9.8, pero eso no significa que el orden de respuesta deba ser idéntico en cualquier entorno. Lo que realmente marca la diferencia es si el servicio afectado está expuesto, si forma parte de la infraestructura básica de la organización y si existe evidencia pública de explotación activa. Por eso, más que repetir una puntuación, interesa interpretar qué representa cada campo del vector y cómo cambia el riesgo según el activo afectado.

En conjunto, el trabajo refuerza una idea bastante simple pero importante: comprobar la información en fuentes primarias es imprescindible. Una noticia o una fuente secundaria ayudan a dar contexto, pero si no se contrastan con NVD, con el aviso del fabricante o con el parche oficial, es fácil exagerar aspectos como la existencia de un 0-day, un supuesto “zero-click” o una explotación activa que en realidad no aparecen confirmados. Probablemente, la parte más útil de la práctica está justo ahí: aprender a separar lo que está documentado de lo que solo parece posible.

En el contexto español, el seguimiento de **INCIBE-CERT** complementa las fuentes internacionales porque publica alertas y avisos traducidos al español, adaptados al tejido empresarial nacional y con recomendaciones orientadas a pymes y administraciones públicas. Muchas organizaciones no consultan de forma sistemática fuentes en inglés como NVD o CISA, por lo que INCIBE-CERT actúa como puente entre esos registros globales y los responsables de seguridad locales. Su seguimiento periódico debería considerarse una práctica básica para cualquier profesional de seguridad que opere en España.

Capítulo 8

Bibliografía

- [1] National Vulnerability Database (NIST), “CVE-2026-33824 Detail,” *nvd.nist.gov*, Abr. 2026. [En línea]. Disponible: <https://nvd.nist.gov/vuln/detail/CVE-2026-33824>. [Accedido: 3 de mayo de 2026].
- [2] National Vulnerability Database (NIST), “CVE-2026-34045 Detail,” *nvd.nist.gov*, 2026. [En línea]. Disponible: <https://nvd.nist.gov/vuln/detail/CVE-2026-34045>. [Accedido: 3 de mayo de 2026].
- [3] National Vulnerability Database (NIST), “CVE-2026-23112 Detail,” *nvd.nist.gov*, Abr. 2026. [En línea]. Disponible: <https://nvd.nist.gov/vuln/detail/CVE-2026-23112>. [Accedido: 3 de mayo de 2026].
- [4] National Vulnerability Database (NIST), “CVE-2026-34078 Detail,” *nvd.nist.gov*, 2026. [En línea]. Disponible: <https://nvd.nist.gov/vuln/detail/CVE-2026-34078>. [Accedido: 3 de mayo de 2026].
- [5] National Vulnerability Database (NIST), “CVE-2025-43359 Detail,” *nvd.nist.gov*, Sep. 2025. [En línea]. Disponible: <https://nvd.nist.gov/vuln/detail/CVE-2025-43359>. [Accedido: 3 de mayo de 2026].
- [6] National Vulnerability Database (NIST), “CVE-2025-43300 Detail,” *nvd.nist.gov*, 2025. [En línea]. Disponible: <https://nvd.nist.gov/vuln/detail/CVE-2025-43300>. [Accedido: 3 de mayo de 2026].
- [7] FIRST.org, “Common Vulnerability Scoring System Version 3.1 Calculator,” *first.org/cvss*, 2026. [En línea]. Disponible: <https://www.first.org/cvss/calculator/3.1>. [Accedido: 3 de mayo de 2026].
- [8] National Vulnerability Database (NIST), “CVSS Calculator / Vulnerability Metrics,” *nvd.nist.gov*, 2026. [En línea]. Disponible: <https://nvd.nist.gov/vuln-metrics/cvss>. [Accedido: 3 de mayo de 2026].
- [9] CISA, “Known Exploited Vulnerabilities Catalog,” *cisa.gov*, 2026. [En línea]. Disponible: <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>. [Accedido: 3 de mayo de 2026].
- [10] INCIBE-CERT, “Avisos de seguridad,” *incibe.es/incibe-cert*, 2026. [En línea]. Disponible: <https://www.incibe.es/incibe-cert>. [Accedido: 3 de mayo de 2026].
- [11] Microsoft Security Response Center, “CVE-2026-33824,” *Security Update Guide*, Abr. 2026. [En línea]. Disponible: <https://msrc.microsoft.com/update-guide/en-us/vulnerability/CVE-2026-33824>. [Accedido: 3 de mayo de 2026].
- [12] Zero Day Initiative, “CVE-2026-33824: Remote Code Execution in Windows IKEv2,” *zerodayinitiative.com*, Abr. 23, 2026. [En línea]. Disponible: <https://www.zerodayinitiative.com/blog>

- [/2026/4/22/cve-2026-33824-remote-code-execution-in-windows-ikev2](#). [Accedido: 3 de mayo de 2026].
- [13] Apple, “About the security content of macOS Tahoe 26,” *support.apple.com*, Sep. 2025. [En línea]. Disponible: <https://support.apple.com/en-us/125110>. [Accedido: 3 de mayo de 2026].
- [14] The Linux Kernel Archives, “nvmet-tcp: add bounds checks in nvmet_tcp_build_pdu_iovec,” *git.kernel.org*, Feb. 2026. [En línea]. Disponible: <https://git.kernel.org/stable/c/043b4307a99f902697349128fde93b2ddde4686c>. [Accedido: 3 de mayo de 2026].
- [15] R. Lakshmanan, “Microsoft Issues Patches for SharePoint Zero-Day and 168 Other New Vulnerabilities,” *The Hacker News*, Abr. 15, 2026. [En línea]. Disponible: <https://thehackernews.com/2026/04/microsoft-issues-patches-for-sharepoint.html>. [Accedido: 3 de mayo de 2026].
- [16] Beeks Group, “Beeks Security Advisory: CVE-2026-23112 – Critical Linux Kernel NVMe/TCP Vulnerability,” *beeksgroup.com*, Abr. 10, 2026. [En línea]. Disponible: <https://beeksgroup.com/security/beeks-security-advisory-cve-2026-23112-critical-linux-kernel-nvme-tcp-vulnerability/>. [Accedido: 3 de mayo de 2026].
- [17] AnuPriya, “Critical Security Flaws in visionOS 26 Fixed as Apple Patches 18 Vulnerabilities,” *Cyber Press*, Sep. 16, 2025. [En línea]. Disponible: <https://cyberpress.org/flaws-in-visionos/>. [Accedido: 3 de mayo de 2026].